

Tunnel: The path that encapsulated packets follow in an Internet VPN.

U.S. Computer Emergency Readiness Team (US-CERT): US-CERT is part of the U.S. Department of Homeland Security's National Cybersecurity and Communications Integration Center in the Office of Cybersecurity and Communications. US-CERT is a partnership between the Department of Homeland Security and the public and private sectors, established to protect the nation's Internet infrastructure. US-CERT coordinates defense against and responses to cyber attacks across the nation.

User identification: The process, control, or information by which a user identifies himself or herself to the system as a valid user (as opposed to authentication).

Utility: A program used to configure or maintain systems, or to make changes to stored or transmitted data.

Virtual local area network (VLAN): Logical segmentation of a LAN into different broadcast domains.

Virtual machine: A software emulation of a physical computing environment.

Virtual private network (VPN): A computer network that uses public telecommunication infrastructure, such as the Internet, to provide remote offices or individual users with secure access to their organization's network.

Virus: Malicious code that replicates itself within a computer.

Vulnerability: A hardware, firmware, or software flaw that leaves an information system open to potential exploitation; a weakness in automated system security procedures, administrative controls, physical layout, internal controls, etc., that could be exploited to gain unauthorized access to information or to disrupt critical processing.

Vulnerability assessment: Systematic examination of systems to identify, quantify, and prioritize the security deficiencies of the systems.

Worm: A self-replicating malware computer program. It uses a computer network to send copies of itself to other nodes (computers on the network), possibly without any user intervention. This occurs primarily because of security vulnerabilities on the target computers.

Zero-day attack: An attack on a piece of software that has a vulnerability for which there is no known patch.

Appendix C: Laws, Regulations, and Guidance

Laws

- 12 USC 1861–1867, “Bank Service Company Act”
- 12 USC 1882, “Bank Protection Act”
- 15 USC 1681w, “Fair and Accurate Credit Transactions Act”
- 15 USC 6801 and 6805(b), “Gramm–Leach–Bliley Act”
- 18 USC 1030, “Fraud and Related Activity in Connection With Computers”

Consumer Financial Protection Bureau

Regulations

- 12 CFR 1005, “Electronic Fund Transfers (Regulation E)”
- 12 CFR 1016, “Privacy of Consumer Financial Information (Regulation P)”

Federal Deposit Insurance Corporation

Regulations

- 12 CFR 326, subpart A, “Minimum Security Procedures”
- 12 CFR 326, subpart B, “Procedures for Monitoring Bank Secrecy Act Compliance”
- 12 CFR 332, “Privacy of Consumer Financial Information”
- 12 CFR 353, “Suspicious Activity Reports”
- 12 CFR 364, appendix A, “Interagency Guidelines Establishing Standards for Safety and Soundness”
- 12 CFR 364, appendix B, “Interagency Guidelines Establishing Information Security Standards”

Guidance

- FIL-28-2015, “Cybersecurity Assessment Tool” (July 2, 2015)
- FIL-13-2015, “FFIEC Joint Statements on Destructive Malware and Compromised Credentials” (March 30, 2015)
- FIL-9-2015, “Business Continuity Planning Booklet Appendix J Update to FFIEC IT Examination Handbook Series” (February 23, 2015)
- FIL-49-2014, “Technology Alert GNU Bourne-Again Shell (Bash) Vulnerability” (September 29, 2014)
- FIL-16-2014, “Technology Alert OpenSSL Heartbleed Vulnerability” (April 11, 2014)
- FIL-11-2014, “Distributed Denial of Service (DDoS) Attacks” (April 2, 2014)
- FIL-10-2014, “ATM and Card Authorization Systems” (April 2, 2014)
- FIL-50-2011, “FFIEC Supplement to Authentication in an Internet Banking Environment” (June 29, 2011)

FIL-56-2010, “Guidance on Mitigating Risk Posed by Information Stored on Photocopiers, Fax Machines and Printers” (September 15, 2010)

FIL-6-2010, “Retail Payment Systems Booklet” (February 25, 2010)

FIL-30-2009, “Identity Theft Red Flags, Address Discrepancies, and Change of Address Regulations Frequently Asked Questions” (June 11, 2009)

FIL-105-2008, “Identity Theft Red Flags, Address Discrepancies, and Change of Address Regulations Examination Procedures” (October 16, 2008)

FIL-100-2007, “Identity Theft Red Flags—Interagency Final Regulation and Guidelines” (November 15, 2007)

FIL-32-2007, “FDIC’s Supervisory Policy on Identity Theft” (April 11, 2007)

FIL-77-2006, “Authentication in an Internet Banking Environment Frequently Asked Questions” (August 21, 2006)

FIL-103-2005, “FFIEC Guidance Authentication in an Internet Banking Environment” (October 12, 2005)

FIL-69-2005, “Guidance on the Security Risks of Voice Over Internet Protocol (VoIP)” (July 27, 2005)

FIL-66-2005, “Spyware—Guidance on Mitigating Risks From Spyware” (July 22, 2005)

FIL-64-2005, “Pharming”—Guidance on How Financial Institutions Can Protect Against Pharming Attacks” (July 18, 2005)

FIL-59-2005, “Identity Theft Study Supplement on ‘Account Hijacking Identity Theft’” (July 5, 2005)

FIL-27-2005, “Final Guidance on Response Programs for Unauthorized Access to Customer Information and Customer Notice” (April 1, 2005)

FIL-7-2005, “Fair and Accurate Credit Transactions Act of 2003 Guidelines Requiring the Proper Disposal of Customer Information” (February 2, 2005)

FIL-132-2004, “Identity Theft Study on ‘Account Hijacking’ Identity Theft and Suggestions for Reducing Online Fraud” (December 14, 2004)

FIL-121-2004, “Computer Software Due Diligence—Guidance on Developing an Effective Software Evaluation Program to Assure Quality and Regulatory Compliance” (November 16, 2004)

FIL-114-2004, “Risk Management of Free and Open Source Software FFIEC Guidance” (October 21, 2004)

FIL-103-2004, “Interagency Informational Brochure on Internet ‘Phishing’ Scams” (September 13, 2004)

FIL-84-2004, “Guidance on Instant Messaging” (July 21, 2004)

FIL-62-2004, “Guidance on Developing an Effective Computer Virus Protection Program” (June 7, 2004)

FIL-27-2004, “Guidance on Safeguarding Customers Against E-Mail and Internet Related Fraud Schemes” (March 12, 2004)

FIL-63-2003, “Guidance on Identity Theft Response Programs” (August 13, 2003)

FIL-43-2003, “Guidance on Developing an Effective Software Patch Management Program” (May 29, 2003)

FIL-30-2003, “Federal Bank and Credit Union Regulatory Agencies Jointly Issue Guidance on the Risks Associated With Weblinking” (April 23, 2003)

FIL-8-2002, “Wireless Networks and Customer Access” (February 1, 2002)

FIL-69-2001, “Authentication in an Electronic Banking Environment” (August 24, 2001)

FIL-68-2001, “501(b) Examination Guidance” (August 24, 2001)
 FIL-39-2001, “Guidance on Identity Theft and Pretext Calling” (May 9, 2001)
 FIL-22-2001, “Security Standards for Customer Information” (March 14, 2001)
 FIL-77-2000, “Bank Technology Bulletin: Protecting Internet Domain Names” (November 9, 2000)
 FIL-67-2000, “Security Monitoring of Computer Networks” (October 3, 2000)
 FIL-68-99, “Risk Assessment Tools and Practices” (July 7, 1999)
 FIL-98-98, “Pretext Phone Calling” (September 2, 1998)
 FIL-131-97, “Security Risks Associated With the Internet” (December 18, 1997)
 FIL-124-97, “Suspicious Activity Reporting” (December 5, 1997)
 FIL-82-96, “Risks Involving Client/Server Computer Systems” (October 8, 1996)

Federal Reserve

Regulations

12 CFR 208.61, “Minimum Security Devices and Procedures”
 12 CFR 208.62, “Reports of Suspicious Activities”
 12 CFR 208.63, “Procedures for Monitoring Bank Secrecy Act Compliance”
 12 CFR 208, appendix D-1, “Interagency Guidelines Establishing Standards for Safety and Soundness”
 12 CFR 208, appendix D-2, “Interagency Guidelines Establishing Information Security Standards”
 12 CFR 211.5(l), “Interagency Guidelines Establishing Information Security Standards”
 12 CFR 211.9, “Interagency Guidelines Establishing Standards for Safeguarding Customer Information”
 12 CFR 211.24(i), “Interagency Guidelines Establishing Information Security Standards”
 12 CFR 225, appendix F, “Interagency Guidelines Establishing Information Security Standards”

Guidance

SR Letter 15-9, “FFIEC Cybersecurity Assessment Tool for Chief Executive Officers and Boards of Directors”
 SR Letter 05-19, “Interagency Guidance on Authentication in an Internet Banking Environment”
 SR Letter 04-17, “FFIEC Guidance on the Use of Free and Open Source Software”
 SR Letter 04-14, “FFIEC Brochure With Information on Internet ‘Phishing’”
 SR Letter 02-18, “Section 312 of the USA Patriot Act—Due Diligence for Correspondent and Private Banking Accounts”
 SR Letter 02-6, “Information Sharing Pursuant to Section 314(b) of the USA Patriot Act”
 SR Letter 01-15, “Safeguarding Customer Information”
 SR Letter 01-11, “Identity Theft and Pretext Calling”
 SR Letter 00-17, “Guidance on the Risk Management of Outsourced Technology Services”
 SR Letter 00-04, “Outsourcing of Information and Transaction Processing”
 SR Letter 99-08, “Uniform Rating System for Information Technology”

SR Letter 97-32, “Sound Practices Guidance for Information Security for Networks”

National Credit Union Administration

Regulations

- 12 CFR 716, “Privacy of Consumer Financial Information & Appendix”
- 12 CFR 721, “Federal Credit Union Incidental Powers Activities”
- 12 CFR 741, “Requirements for Insurance”
- 12 CFR 748, “Security Program, Report of Crime and Catastrophic Act and Bank Secrecy Act Compliance & Appendices”

Guidance

- NCUA Letter to Credit Unions 05-CU-20, “Phishing Guidance for Credit Unions and Their Members”
- NCUA Letter to Credit Unions 05-CU-18, “Guidance on Authentication in Internet Banking Environment” (November 2005)
- NCUA Letter to Credit Unions 04-CU-12, “Phishing Guidance for Credit Union Members” (September 2004)
- NCUA Letter to Credit Unions 04-CU-06, “E-Mail and Internet Related Fraudulent Schemes Guidance” (May 2004)
- NCUA Letter to Credit Unions 04-CU-05, “Fraudulent E-Mail Schemes” (May 2004)
- NCUA Letter to Credit Unions 03-CU-14, “Computer Software Patch Management” (September 2003)
- NCUA Letter to Credit Unions 03-CU-12, “Fraudulent Newspaper Advertisements, and Websites by Entities Claiming to Be Credit Unions” (August 2003)
- NCUA Letter to Credit Unions 03-CU-08, “Weblinking: Identifying Risks & Risk Management Techniques” (April 2003)
- NCUA Letter to Credit Unions 03-CU-03, “Wireless Technology” (March 2003)
- NCUA Letter to Credit Unions 02-CU-13, “Vendor Information Systems & Technology Reviews—Summary Results” (July 2002)
- NCUA Letter to Federal Credit Unions 02-FCU-11, “Tips to Safely Conduct Financial Transactions Over the Internet—An NCUA Brochure for Credit Union Members” (July 2002)
- NCUA Letter to Credit Unions 02-CU-08, “Account Aggregation Services” (April 2002)
- NCUA Letter to Federal Credit Unions 02-FCU-04, “Weblinking Relationship” (March 2002)
- NCUA Letter to Credit Unions 01-CU-21, “Disaster Recovery and Business Resumption Contingency Plans” (December 2001)
- NCUA Letter to Credit Unions 01-CU-20, “Due Diligence Over Third-Party Service Providers” (November 2001)
- NCUA Letter to Credit Unions 01-CU-12, “E-Commerce Insurance Considerations” (October 2001)

NCUA Letter to Credit Unions 01-CU-11, “Electronic Data Security Overview” (August 2001)
 NCUA Letter to Credit Unions 01-CU-10, “Authentication in an Electronic Banking Environment” (August 2001)
 NCUA Letter to Credit Unions 01-CU-09, “Identity Theft and Pretext Calling” (September 2001)
 NCUA Regulatory Alert 01-RA-03, “Electronic Signatures in Global and National Commerce Act (E-Sign Act)” (March 2001)
 NCUA Letter to Credit Unions 01-CU-04, “Integrating Financial Services and Emerging Technology” (March 2001)
 NCUA Letter to Credit Unions 01-CU-02, “Privacy of Consumer Financial Information” (February 2001)
 NCUA Letter to Credit Unions 00-CU-11, “Risk Management of Outsourced Technology Services (With Enclosure)” (December 2000)
 NCUA Letter to Credit Unions 00-CU-07, “NCUA’s Information Systems & Technology Examination Program” (October 2000)
 NCUA Letter to Credit Unions 00-CU-04, “Suspicious Activity Reporting” (June 2000)
 NCUA Letter to Credit Unions 00-CU-02, “Identity Theft Prevention” (May 2000)
 NCUA Regulatory Alert 99-RA-3, “Pretext Phone Calling by Account Information Brokers” (February 1999)
 NCUA Regulatory Alert 98-RA-4, “Interagency Guidance on Electronic Financial Services and Consumer Compliance” (July 1998)
 NCUA Letter to Credit Unions 97-CU-05, “Interagency Statement on Retail On-Line PC Banking” (April 1997)
 NCUA Letter to Credit Unions 97-CU-01, “Automated Response System Controls” (January 1997)
 NCUA Letter to Credit Unions 109, “Information Processing Issues” (September 1989)

Office of the Comptroller of the Currency

Regulations

12 CFR 21, subpart A, “Minimum Security Devices and Procedures”
 12 CFR 21, subpart B, “Reports of Suspicious Activities”
 12 CFR 21, subpart C, “Procedures for Monitoring Bank Secrecy Act Compliance”
 12 CFR 30, appendix A, “Interagency Guidelines Establishing Standards for Safety and Soundness”
 12 CFR 30, appendix B, “Interagency Guidelines Establishing Information Security Standards”
 12 CFR 41.83, “Proper Disposal of Records Containing Customer Information”

Guidance

OCC Bulletin 2016-18, “Cybersecurity of Interbank Messaging and Wholesale Payment Networks: FFIEC Statement” (June 7, 2016)

- OCC Bulletin 2016-14, “FFIEC Information Technology Examination Handbook: Mobile Financial Services, New Appendix to the Retail Payment Systems Booklet” (April 29, 2016)
- OCC Bulletin 2015-44, “FFIEC Information Technology Examination Handbook: Revised Management Booklet” (November 10, 2015)
- OCC Bulletin 2015-40, “Cybersecurity: Joint Statement on Cyber Attacks Involving Extortion” (November 3, 2015)
- OCC Bulletin 2015-31, “FFIEC Cybersecurity Assessment Tool” (June 30, 2015)
- OCC Bulletin 2015-20, “Cybersecurity: Destructive Malware Joint Statement” (March 30, 2015)
- OCC Bulletin 2015-19, “Cybersecurity: Cyber Attacks Compromising Credentials Joint Statement” (March 30, 2015)
- OCC Bulletin 2015-9, “FFIEC Information Technology Examination Handbook: Strengthening the Resilience of Outsourced Technology Services, New Appendix for Business Continuity Planning Booklet” (February 6, 2015)
- OCC Bulletin 2014-53, “Cybersecurity Assessment General Observations and Statement” (November 3, 2014)
- OCC Bulletin 2014-17, “Information Security Vulnerability in OpenSSL Encryption Tool (Heartbleed): Joint Statement” (April 25, 2014)
- OCC Bulletin 2014-14, “Distributed Denial-of-Service Cyber Attacks, Risk Mitigation, and Additional Resources: Joint Statement” (April 3, 2014)
- OCC Bulletin 2014-13, “Cyber Attacks on Financial Institutions’ Automated Teller Machine and Card Authorization Systems: Joint Statement” (April 2, 2014)
- OCC Bulletin 2013-29, “Third-Party Relationships: Risk Management Guidance” (October 30, 2013)
- OCC Bulletin 2013-22, “Windows XP Operating System: Joint Statement” (October 7, 2013)
- OCC Bulletin 2011-26, “Authentication in an Internet Banking Environment: Supplement” (June 28, 2011)
- OCC Bulletin 2008-16, “Information Security: Application Security” (May 8, 2008)
- OCC Bulletin 2007-45, “Identity Theft Red Flags and Address Discrepancies: Final Rulemaking” (November 14, 2007)
- OCC Bulletin 2005-35, “Authentication in an Internet Banking Environment: Interagency Guidance” (October 12, 2005)
- OCC Bulletin 2005-24, “Threats From Fraudulent Bank Web Sites: Risk Mitigation and Response Guidance for Web Site Spoofing Incidents” (July 1, 2005)
- OCC Bulletin 2005-13, “Response Programs for Unauthorized Access to Customer Information and Customer Notice: Final Guidance: Interagency Guidance” (April 14, 2005)
- OCC Bulletin 2005-1, “Proper Disposal of Consumer Information: Final Rule” (January 12, 2005)
- OCC Bulletin 2001-35, “Examination Procedures to Evaluate Compliance With the Guidelines to Safeguard Customer Information: Examination Procedures” (July 18, 2001)
- OCC Bulletin 2001-8, “Guidelines Establishing Standards for Safeguarding Customer Information: Final Guidelines” (February 15, 2001)
- OCC Bulletin 2000-14, “Infrastructure Threats—Intrusion Risks: Message to Bankers and Examiners” (May 15, 2000)

OCC Bulletin 1999-20, "Certificate Authority Systems: Guidance for Bankers and Examiners" (May 4, 1999)
OCC Bulletin 1998-3, "Technology Risk Management: Guidance for Bankers and Examiners" (February 4, 1998)
OCC Alert 2001-4, "Network Security Vulnerabilities" (April 24, 2001)
OCC Alert 2000-9, "Protecting Internet Addresses of National Banks" (July 19, 2000)

Other References

Basel Committee on Banking Supervision, "Sound Practices for the Management and Supervision of Operational Risk" (February 2003)
ISACA Control Objectives for Enterprise IT Governance